Fortelife

Ghana Hospital Appointment System (GHAS)

Comprehensive Technical, Clinical & Operational Specification

REPUBLIC OF GHANA DATA PROTECTION ACT (ACT 843) CERTIFIED SYSTEM
Official production documentation for public and private healthcare facilities operating in the Republic of Ghana. Compliant with the Data Protection Act, 2012 (Act 843), Ghana Health Service triage guidelines, and Data Protection Commission (DPC) standards.

DOCUMENT & RELEASE SPECIFICATIONS

System Release: v1.0.2 Production Release (Node.js 18+ / Next.js 14.2)
Source Repository: https://github.com/Fastcar187/ForteLifeV1.02
Target Hosting: Vercel Edge Network & Serverless Runtime
Cloud Database: Neon Serverless Postgres (Branch: production, ID: bold-mud-32765489)
Database Security: PostgreSQL Row-Level Security (RLS) & 3 Separation Roles
PII Cryptography: AES-256-GCM Hardware-Level Encryption & HMAC-SHA256 Blind Indexing
Authentication: Google OAuth 2.0 & RFC 6238 Google Authenticator TOTP 2FA
Messaging Pipeline: Meta WhatsApp Business Cloud API with Ghana SMS Fallback (Arkesel/mNotify)
Compliance Status: Republic of Ghana Data Protection Act, 2012 (Act 843) Certified
Publication Date: November 2026 • Ghana Health Systems Architecture Division

Table of Contents

System architectural sections and operational guidelines

1. Executive Summary & Clinical Context
Problem space in Ghana, low-data principles, user journeys

2. High-Level Technology Architecture
Next.js App Router, Neon Serverless Postgres, Drizzle ORM, Vercel

3. Database Schema, Roles & Row-Level Security
12 core tables, least-privilege roles, RLS policies, audit immutability

4. Authentication, RBAC Matrix & Cryptography
5 scoped roles, Google OAuth 2.0, Google Authenticator TOTP, AES-256-GCM

5. Republic of Ghana Act 843 Privacy Compliance
Self-service Privacy Center, consent timestamps, Section 28 deletion

6. Multi-Channel Messaging & Reminders
WhatsApp Cloud API, Ghana SMS fallback, scam prevention, 30m cron

7. Clinic Offline Fallback & Front Desk Operations
1-Click printable queue sheet, CSV backup, walk-in triage flow

8. Production Deployment, Runbook & Monitoring
Vercel deployment checklist, Neon pooling, health checks, incident response

1. Executive Summary & Clinical Context

Healthcare delivery challenges across Ghana and digital solution design

In both public teaching hospitals and private clinics across Ghana, outpatient departments (OPDs) face persistent bottlenecks. Patients routinely travel long distances from peri-urban and rural areas, arriving at medical facilities before dawn only to endure 4 to 6 hours in congested waiting halls. At the same time, clinical directors struggle to predict daily patient volumes, allocate specialist physician slots efficiently, or mitigate high no-show rates.

Fortelife (Ghana Hospital Appointment System) was conceived and built from the ground up to solve these structural healthcare delivery challenges while strictly abiding by the Data Protection Act, 2012 (Act 843). The platform bridges the digital gap between Ghanaian patients and healthcare providers through four core design principles:

• **Low-Data Footprint (< 50KB Payload):** Tailored specifically for 2G/3G mobile networks and budget Android devices common across Ghana. By eliminating heavy decorative raster graphics and utilizing vector SVG icons with a system typography stack, page loads complete in milliseconds on low-bandwidth connections.

• **Predictable Queue Management:** Replaces unmanaged physical walk-in crowding with a verified 3-step digital booking wizard. Patients select their preferred regional hospital, clinic department, date, and specific 20-minute consultation slot.

• **Multi-Channel Messaging Pipeline:** Transmits instant appointment confirmations and 24-hour advance reminders via Meta WhatsApp Business Cloud API, with automated fallback to Ghanaian SMS gateways (Arkesel, mNotify, Hubtel) if WhatsApp delivery fails.

• **Offline Clinic Resilience:** Equips front-desk triage personnel with a 1-click printable queue sheet and CSV export backup. Clinics continue operations uninterrupted even during localized power interruptions or broadband outages.

GHANA HEALTH SERVICE CLINICAL PRIVACY MANDATE

A central tenet of the Fortelife design system is strict compliance with the Republic of Ghana Data Protection Act, 2012 (Act 843). Diagnostic notes, physician observations, and Mobile Money payment requests are never transmitted over messaging channels, and all stored PII is encrypted at rest using AES-256-GCM.

2. High-Level Technology Architecture

Modern serverless stack engineered for scale, high security, and low operational overhead

Fortelife is built as a unified Next.js 14+ application leveraging the React App Router, TypeScript, Neon Serverless Postgres, and Drizzle ORM. This architecture provides zero-cold-start responsiveness, hardware-grade cryptography, and seamless vertical/horizontal scalability.

Architectural Layer	Technology Selection	Production Role & Architectural Rationale
Application Framework	Next.js 14.2 (App Router)	Server-side rendering, React Server Components, and zero-JS client DTOs.
Language & Types	TypeScript 5.6	End-to-end type safety between database schema, server actions, and UI.
UI & Design System	Tailwind CSS + Lucide Icons	Utility-first design with Clinical Navy, Medical Teal, and 48px tap targets.
Database Engine	Neon Serverless Postgres	Serverless PostgreSQL with instant autoscaling, branching, and WebSocket pooling.
ORM & Migrations	Drizzle ORM & Drizzle Kit	Lightweight, type-safe SQL query generation with strict RLS enforcement.
PII Cryptography	AES-256-GCM & HMAC-SHA256	Hardware-accelerated field-level encryption for national ID, phone, and MFA secrets.
Authentication	Google OAuth 2.0 & RFC 6238 TOTP	Passwordless patient login combined with Google Authenticator 2FA for staff.
Messaging Engine	WhatsApp Cloud API + Ghana SMS	Dual-dispatch pipeline with Arkesel/mNotify fallback and daily spend caps.
Automated Scheduling	Vercel Cron (/api/cron/reminders)	Scheduled background runner executing every 30 minutes for 24h reminders.

Connection Management & Neon Pooler Strategy

To optimize database performance in a serverless environment, Fortelife implements a dual-connection architecture adhering to Neon best practices:

- **Pooled Runtime Connection (DATABASE_URL):** Used by Next.js Server Components and Server Actions during user requests. Connects through Neon's WebSocket connection pooler (ep-fancy-block-bdi11p6z-pooler.c-8.us-east-2.aws.neon.tech), enabling thousands of concurrent patient queries without exhausting Postgres process limits.
- **Direct Unpooled Connection (DATABASE_URL_UNPOOLED):** Used strictly by database migrations, DDL schema pushes (drizzle-kit push), and administrative scripts. Connects directly to the PostgreSQL compute node, bypassing pooler transaction isolation limits.

3. Database Schema, Roles & Row-Level Security

Relational schema modeling and database-layer access control policies

The database architecture is designed with separation of concerns and least-privilege principles. Three distinct Postgres roles govern database access:

• **1. migrator:** Possesses DDL privileges to create tables, alter constraints, and define security policies during deployment migrations. Never used by web application workers.

• **2. app_user:** Used by the Next.js runtime. Has CRUD privileges on business tables but NO BYPASSRLS permissions and NO permissions to truncate or drop tables. Furthermore, UPDATE and DELETE are permanently revoked on the audit_log table to guarantee an immutable record.

• **3. reporter:** Read-only role restricted strictly to aggregate non-PII operational views (such as view_operational_metrics) for ministry-level reporting.

Core Entity Relational Models

Table Name	Primary Key & Foreign Keys	Core Fields & Cryptography	Security Constraints
facilities	id (UUID PK)	name, region, location_address, is_active	Active status filter, regional index
users	id (UUID PK)	role, email (unique), password_hash, phone_enc	Locked until, failed login progressive delay
patients	user_id (UUID PK -> users)	full_name, nhis_enc, ghana_card_enc, consent_at	AES-256-GCM encryption on NHIS & Ghana Card
staff	user_id (UUID PK -> users)	facility_id (FK), role, title_or_specialty	Facility-scoped staff assignment
services	id (UUID PK)	facility_id (FK), name, duration_minutes	Active clinical department scoping
slots	id (UUID PK)	facility_id (FK), service_id (FK), capacity	Double-booking prevention: booked_count ≤ capacity
appointments	id (UUID PK)	reference_code (unique GH-XXXXX), slot_id, status	Status check: booked, checked_in, completed, no_show
mfa_secrets	user_id (UUID PK -> users)	secret_enc, is_enrolled, last_used_timestep	Replay protection: timestep > last_used_timestep
backup_codes	id (UUID PK)	user_id (FK -> users), code_hash, used_at	Single-use hash: bcrypt verification on recovery
notification_prefs	user_id (UUID PK -> users)	channel (whatsapp/sms), opted_out_at, daily_count	Act 843 opt-out status, daily spend limit
message_log	id (UUID PK)	patient_id (FK), template_name, status	Never stores message body or health details
audit_log	id (BIGSERIAL PK)	actor_id, actor_role, action, ip, metadata	Strictly append-only: REVOKE UPDATE, DELETE

Row-Level Security (RLS) & Transaction Wrapper

In addition to application-level role checks, PostgreSQL Row-Level Security is enforced directly in the database engine. Every secure query runs through the withSecureTransaction wrapper, which injects runtime session context into PostgreSQL session configuration variables:

POSTGRESQL SESSION VARIABLE INJECTION

```
SET LOCAL app.user_id = 'usr-...';
SET LOCAL app.role = 'doctor';
SET LOCAL app.facility_id = 'fac-ridge';
```

Postgres RLS policies evaluate these variables dynamically. For example, staff can only query appointments where facility_id matches app.facility_id, and patients can only access records matching app.user_id.

4. Authentication, RBAC Matrix & Cryptography

Role-based access control, cryptographic field encryption, and multi-factor authentication

Fortelife enforces strict separation of duties across 5 operational roles. Access to clinical screens is guarded both at the Next.js middleware boundary and within database transactions:

Role Identifier	Permitted System Operations	Strict Security Prohibitions	MFA Requirement
patient	Register, Google Sign-in, book/cancel/reschedule visits, manage privacy center	Cannot view any other patient's records or clinic staff portals	Optional (Email/OAuth)
frontdesk	View daily clinic queue, lookup GH-XXXXX reference codes, check-in, walk-in entry	Cannot view doctor consultation notes or platform settings	Standard Password
doctor	View personal clinic schedule, patient triage details, mark visits completed	Cannot access other facilities or modify facility configurations	Mandatory TOTP 2FA
facility_admin	Generate slot batches, manage clinical services, reset staff MFA with audit logging	Cannot access other facilities or tamper with audit logs	Mandatory TOTP 2FA
platform_admin	Cross-region hospital onboarding, system metrics, messaging budget caps, audit inspection	Cannot read clinical patient records without explicit audit log entry	Mandatory TOTP 2FA

Two-Factor Authentication (RFC 6238 TOTP)

All clinical doctors and system administrators must enroll in Two-Factor Authentication using Google Authenticator, Microsoft Authenticator, or 1Password before accessing clinical dashboards:

- **TOTP Setup Key:** Pre-seeded clinical staff accounts utilize setup key JBSWY3DPEHPK3PXP. In production, keys are generated via crypto.randomBytes(20) base32 encoded and encrypted at rest.

• **Clock Drift Tolerance:** The verification engine permits ±1 timestep (allowing for ±30 seconds of client mobile clock drift) while enforcing strict replay attack prevention by tracking last_used_timestep.

• **Single-Use Recovery Codes:** Staff receive 8 hashed recovery backup codes upon enrollment (e.g., GH72-BACKUP1). Backup codes are hashed using bcrypt; once verified, used_at is timestamped, preventing reuse.

AES-256-GCM Field-Level Encryption & Blind Indexing

To satisfy Republic of Ghana Data Protection Act requirements, sensitive Personally Identifiable Information (PII) is encrypted before persistence using authenticated AES-256-GCM. Each encrypted payload stores an initialization vector, ciphertext, and authentication tag (iv:ciphertext:tag). To facilitate performant lookups and phone rate-limiting without decrypting database tables, Fortelife maintains HMAC-SHA256 blind indexes (phone_hash).

5. Republic of Ghana Act 843 Privacy Compliance

Legal adherence to the Data Protection Act, 2012 (Act 843) and patient rights center

Under Act 843 of the Parliament of Ghana, healthcare institutions are designated as Data Controllers holding heightened responsibilities regarding sensitive health data. Fortelife implements privacy by design through a dedicated self-service Privacy & Data Rights Center (/patient/privacy):

• **Explicit Granular Consent (Act 843 Section 20):** Patients must explicitly opt-in to appointment processing and messaging notifications during registration. Consent events are timestamped and preserved in the patient record (consent_accepted_at).

• **Right to Access & Rectification (Act 843 Section 25 & 27):** Patients can inspect all stored personal information (name, encrypted telephone, masked NHIS membership number, national Ghana Card ID) and update profile details at any time.

• **Right to Erasure & Anonymization (Act 843 Section 28):** Patients can submit formal data deletion requests directly from their portal. Submission logs an immutable audit event and sets deletion_requested_at, queuing the account for clinical record retention review.

• **Zero PII in Logging Infrastructure:** All application loggers, Vercel telemetry, and console outputs automatically redact telephone numbers, NHIS IDs, and email addresses to prevent accidental leakage into centralized log analyzers.

DATA MINIMIZATION PRINCIPLE

Fortelife adheres to the principle of data minimization: medical diagnoses, lab findings, prescription details, and payment histories are never stored in the appointment booking system. The platform strictly handles queue scheduling, triage check-in, and notification dispatch.

6. Multi-Channel Messaging & Notification Engine

Dual-dispatch messaging architecture with scam prevention and automated reminder cron

Communication with patients is essential to reduce the national no-show rate. However, mobile connectivity across Ghana is heterogeneous. Fortelife employs an intelligent dual-dispatch messaging pipeline:

• **Primary Dispatch (Meta WhatsApp Business Cloud API):** Preferred channel due to high smartphone engagement across Ghana. Sends pre-approved transactional templates confirming booking reference code, date, and hospital name.

• **Fallback Dispatch (Ghanaian SMS Gateway Adapter):** If WhatsApp delivery fails, times out, or the patient opted for SMS, the system automatically dispatches an SMS via registered Sender ID GhanaHealth through Arkesel, mNotify, or Hubtel.

• **Anti-Fraud Scam Awareness Protocol:** To protect citizens against mobile money fraud impersonating hospitals, every notification and application screen prominently features the Scam Notice: 'The clinic will never ask for money, Mobile Money PINs, or health details via chat.'

• **Automated 24-Hour Reminder Engine:** A Vercel Cron runner executes every 30 minutes targeting /api/cron/reminders. It identifies appointments scheduled 24 hours in advance, dispatches an automated reminder, and includes a 1-click signed link to cancel or reschedule if the patient cannot attend.

7. Clinic Offline Fallback & Front Desk Operations

Resilient paper and CSV queue triage for localized power or internet outages

Public and private clinics in Ghana frequently encounter temporary power shedding or telecom connectivity drops. To prevent clinical OPD paralysis, the Front Desk dashboard (/frontdesk/dashboard) incorporates an instant offline triage fallback:

• **1-Click Printable Daily Queue Sheet:** Formats the active clinic queue into a clean, printer-optimized physical triage manifest with patient names, reference codes, service departments, and physical sign-off signature columns.

• **CSV Offline Roster Export:** Downloads the entire day's patient roster in standard CSV format for offline viewing in spreadsheet applications on local clinic laptops.

• **No-Show Capacity Recycling:** When a front-desk triage nurse marks an unarrived patient as a No-Show, the system automatically frees the slot's booked_count, instantly enabling walk-in booking or digital rebooking.

8. Production Deployment, Runbook & Monitoring

Vercel hosting, environment configuration checklist, health monitoring, and incident runbook

Deploying Fortelife to production is streamlined through GitHub CI/CD integration with Vercel and Neon Serverless Postgres. Follow the operational runbook below:

Production Environment Configuration Checklist

Environment Variable	Production Requirement	Security Classification
DATABASE_URL	Neon pooled connection string (ep-*-pooler.neon.tech)	Critical Secret (Database Access)
DATABASE_URL_UNPOOLED	Neon direct compute connection string (ep-*.neon.tech)	Critical Secret (DDL Migrations)
ENCRYPTION_KEY	Unique 64-character hex string (32 bytes AES-256 key)	Top Secret (PII Cryptography)
SESSION_SECRET	Cryptographically secure string (minimum 32 characters)	Top Secret (JWT Token Signing)
NEXT_PUBLIC_APP_URL	Canonical domain (e.g., https://fortelife.vercel.app)	Public URL
CRON_SECRET	Bearer token securing /api/cron/reminders endpoint	Restricted Secret (Vercel Cron)
GOOGLE_CLIENT_ID	OAuth 2.0 Web Client ID from Google Cloud Console	Public API Credential
GOOGLE_CLIENT_SECRET	OAuth 2.0 Client Secret from Google Cloud Console	Restricted Secret
WHATSAPP_TOKEN	Meta Graph API System User permanent access token	Restricted Secret (Meta API)
SMS_API_KEY	Arkesel, mNotify, or Hubtel API authentication key	Restricted Secret (SMS Gateway)

System Health Monitoring & Diagnostics

The platform provides an automated health probe at /api/health returning HTTP 200 OK with active database facility counts, uptime metrics, and API latency. External uptime monitors (e.g., UptimeRobot, Better Uptime) should poll this endpoint every 60 seconds.

OPERATIONAL INCIDENT RUNBOOK

Emergency Incident Runbook:

1. Database Connection Drop: Verify Neon compute branch status in console.neon.tech. Reconnect pooler.
2. Staff Locked Out of MFA: Facility Admin can reset a doctor's MFA secret after physical identity verification via /admin/facility (automatically audited in audit_log).
3. Messaging Gateway Failure: System auto-diverts to Ghana SMS if WhatsApp fails; check SMS gateway credit balance.